

1. Purpose

To assess the security value of geo-restrictions in Microsoft Entra ID Conditional Access policies given the widespread availability of VPN and proxy services and describe their effect on authorized TD SYNEX access to end customer environments.

2. Table of Contents

1.	Purpose	1
2.	Table of Contents	1
3.	Reference	1
3.1.	TD SYNEX Access	1
3.2.	The Security Question	2
3.3.	How Conditional Access Evaluates Location	2
3.4.	Why a Country Condition Is Not a Boundary	3
3.5.	Observed Techniques for Defeating Geographic Restrictions	3
3.5.1.	Commercial VPN Services and Virtual Private Servers	3
3.5.2.	Residential and Mobile Proxy Networks	3
3.5.3.	Compromised Edge Devices and Relay Networks	3
3.5.4.	Hyperscaler and Cloud Provider Infrastructure	4
3.5.5.	In-Region Footholds and Legitimate Remote Access	4
3.5.6.	Token Theft and Session Replay	4
3.6.	What Geographic Restrictions Still Provide	5
3.7.	Reconciling Geographic Restrictions with a Layered Model	5
3.8.	Operational Costs and Failure Modes	5
3.9.	Recommendations	6
3.10.	Summary Position	7
4.	Associated Documents	7
4.1.	Microsoft Reference Documents	7
4.2.	Microsoft Techniques Documents	8
4.3.	Government Documents	8
4.4.	Associated TD SYNEX Documents	8
5.	Document Approval	8
6.	Document Revision History	8
7.	Appendix A – Glossary	9
8.	Appendix B – Summary of Techniques Used to Defeat Geographic Restrictions	11
9.	Appendix C – Positioning Geographic Restriction Within a Layered Model	12

3. Reference

3.1. TD SYNEX Access

TD SYNEX is a global organization with operations and personnel located worldwide. TD SYNEX maintains support and service teams across multiple regions. Microsoft break/fix support resources are located primarily in India, the Philippines, and Costa Rica, although these locations are subject to change without notice.

Geo-location blocking policies that restrict access by country or region may inadvertently block TD SYNEX engineers from accessing end customer environments. When this occurs, TD SYNEX's

ability to provide timely support to end customers may be delayed or prevented. These restrictions may also impact TD SYNnex's ability to engage Microsoft support on behalf of end customers when required.

TD SYNnex recommends excluding authorized TD SYNnex service provider accounts from geo-location-based access restrictions. TD SYNnex maintains a comprehensive security program aligned with Microsoft security best practices, including a mandatory multi-factor authentication (MFA) requirement for all users within our Partner Center environments.

Due to the scale of TD SYNnex's global operations and the dynamic nature of our network infrastructure, TD SYNnex is unable to provide or maintain a definitive list of IP addresses for exclusion. As a result, identity-based access controls are generally more effective and manageable than IP-based exceptions.

3.2. The Security Question

A recurring question raised by end customers and partners is whether country or region-based restrictions in Entra ID Conditional Access provide meaningful security, given that commercial virtual private network (VPN) services are inexpensive, widely available, and trivial to operate. This question is valid and requires a distinction between preventive controls and traffic reduction mechanisms.

Geographic restrictions represent a low-assurance control that can reduce opportunistic activity, provide valuable investigative telemetry, and support specific regulatory or compliance requirements. However, they should not be regarded as a security boundary or relied upon as a primary access control mechanism. A threat actor intentionally targeting a specific tenant can typically circumvent country-based restrictions with minimal effort, often by altering the apparent geographic source of traffic. This technique does not require access to the target environment, exploitation of a vulnerability, or privileged knowledge of the tenant.

3.3. How Conditional Access Evaluates Location

Location in Conditional Access is derived from the network path, not from the identity or the device. Entra ID determines a user's location from the public IP address presented during authentication, or from GPS coordinates supplied by the Microsoft Authenticator app. For a country or region named location configured to determine location by IP address, Entra ID resolves the IPv4 or IPv6 address against a periodically updated mapping table. Addresses that cannot be resolved to a country fall into an unknown category that an administrator must explicitly choose to include or exclude.

Two properties of this mechanism carry directly on the security question. First, Conditional Access policies are enforced after first-factor authentication completes, and Microsoft states plainly that Conditional Access is not intended to be an organization's front line of defense. A sign-in blocked by a country condition still represents a credential that was submitted and evaluated. Second, when a cloud-hosted proxy or VPN sits in the path, the address Entra ID evaluates is the address of the proxy. The X-Forwarded-For header, which would carry **the user's original public address**, is deliberately not honored because its origin cannot be validated and it could be forged.

Location is also not evaluated continuously under default settings. Policy is applied at initial sign-in, and for clients using modern authentication it is reapplied when a refresh token is exchanged for a new access token, which by default occurs approximately once per hour. A change in network location is therefore typically detected within an hour rather than at the moment it happens.

GPS-based named locations move the signal closer to the device and are harder to spoof, but they carry significant constraints. They require the Microsoft Authenticator app, hourly location sharing with user consent, and platform jailbreak detection, and the app denies authentication where the reported location does not match the device's actual GPS position. Microsoft advises reserving this option for highly sensitive applications, because users may be prompted every hour.

3.4. Why a Country Condition Is Not a Boundary

The effectiveness of a control should be evaluated against the cost it imposes on the adversary. A country condition costs an adversary very little. Consumer VPN services advertise exit nodes in dozens or hundreds of countries and present country selection as a menu item, with subscriptions priced at a few dollars per month and free tiers widely available. Virtual private servers can be provisioned in a chosen country within minutes for a comparable amount. Presenting an approved country is therefore a single configuration change made entirely on the adversary's side of the connection. It requires no access to the defender's environment, no vulnerability, and no privileged knowledge.

The resulting asymmetry works against the defender. The organization absorbs ongoing operational cost in the form of location definitions to maintain, exceptions to manage for travelers, partners, and incident responders, and lockout risk during emergencies. The adversary absorbs a cost measured in minutes and single-digit dollars. More importantly, the traffic that survives the filter is precisely the traffic that was motivated enough to route around it. A country condition applied on its own removes indiscriminate noise while leaving targeted activity untouched, and it can create the impression of a perimeter where none exists.

3.5. Observed Techniques for Defeating Geographic Restrictions

The techniques below are drawn from publicly documented Microsoft Threat Intelligence reporting and from Microsoft product documentation. They are presented to illustrate why apparent source country is a weak assertion, and they progress roughly from the least to the most difficult to detect.

3.5.1. Commercial VPN Services and Virtual Private Servers

The simplest method is a commercial VPN subscription or a rented virtual private server. Microsoft Threat Intelligence documents this pattern in its reporting on Jasper Sleet, the North Korea aligned remote IT worker operation. Those workers, located primarily in North Korea, China, and Russia, use VPN services, virtual private servers, proxy services, and remote monitoring and management tooling to conceal their true location and identity while holding paid employment at target organizations. Microsoft names Astrill VPN specifically among the services observed. In this scenario the account is real, the credential is real, and the country presented to Entra ID is simply whichever one the operator selects from a list.

3.5.2. Residential and Mobile Proxy Networks

Residential proxy services route traffic through IP addresses assigned to ordinary consumer broadband and mobile subscribers. Traffic exits from address space that is indistinguishable, by geolocation lookup, autonomous system number, or address reputation, from the traffic of legitimate users in that country. Microsoft's published responder guidance on the Midnight Blizzard intrusion states that the actor used residential proxy networks as part of multiple attempts to obfuscate the source of the attack, routing traffic through a very large number of IP addresses that are also used by legitimate users.

This technique defeats country conditions and address-based blocking at the same time. If an organization permits its own home country, as nearly all do, the attack simply arrives from inside the permitted set. Because the address pool is very large and rotates continuously, blocking individual addresses yields no durable benefit, and blocking the ranges wholesale would block genuine customers, employees, and mobile users.

3.5.3. Compromised Edge Devices and Relay Networks

State-aligned actors frequently avoid commercial proxy services and build relay infrastructure from compromised devices instead. Microsoft's reporting on Volt Typhoon describes an actor that blends into normal network activity by routing traffic through compromised small office and home office network equipment, including routers, firewalls, and VPN hardware, and that uses customized

versions of open-source tools to establish a command and control channel over proxy. Public advisories on the same activity note that the compromised devices were often located in the same geographic area as the victim.

From a geolocation standpoint this is materially worse than a commercial VPN. The exit address belongs to a genuine residential or small business connection inside the permitted country, carries clean reputation, and sits in a plausible autonomous system. Nothing about the address distinguishes it from a branch office or a home worker. A country condition provides no signal whatsoever against this pattern, and address reputation feeds provide very little.

3.5.4. Hyperscaler and Cloud Provider Infrastructure

Public cloud platforms allow any party holding a payment instrument to provision compute in a chosen region within minutes. A virtual machine, container, or serverless function deployed into a region presents a public address that geolocates to that region, which reduces geographic placement to a billing decision. Compromised or fraudulently obtained subscriptions remove even that cost, and the resulting traffic originates from address space that most organizations already treat as ordinary business traffic.

Four properties of hyperscaler address space make it especially effective against country conditions. Provider address ranges are reassigned frequently, so attribution of an address to a particular tenant is unreliable and short lived. Managed egress services, network address translation gateways, and provider-hosted relay services place many unrelated customers behind a small number of shared addresses, which makes any block over-broad. Content delivery networks and application front ends further separate the true origin of a request from the address a resource observes. Finally, blocking cloud provider ranges outright is impractical for most organizations, because legitimate software as a service integration, automation, monitoring, and backup traffic originate from the same address space. The practical result is that cloud-originated traffic is frequently treated as more trustworthy than average rather than less.

3.5.5. In-Region Footholds and Legitimate Remote Access

An adversary who already holds any foothold inside a permitted country inherits that country's standing automatically. A compromised endpoint, a hijacked remote monitoring and management session, or a stolen virtual desktop credential all place the adversary's traffic behind a legitimate in-country egress point, with no proxy infrastructure required.

Microsoft's Jasper Sleet reporting describes a deliberate industrialization of this idea. Facilitators located in the country of the role operate laptop farms that give company-issued hardware an internet connection at the geographic location the employer expects, while the operator connects to that hardware from abroad using remote access tooling such as TeamViewer, AnyDesk, RustDesk, and comparable products. Every location signal available to the employer is genuine. The person behind the session is not.

3.5.6. Token Theft and Session Replay

The techniques described above defeat the location condition by controlling where an authentication appears to originate. Token theft bypasses the condition rather than defeating it. Adversary-in-the-middle phishing and information-stealing malware capture the session artifacts issued after a successful authentication, including refresh tokens and session cookies. Those artifacts can then be replayed from any location, because the location condition was evaluated and satisfied at the moment they were issued.

Microsoft addresses this gap through continuous access evaluation. In the standard mode, a short-lived token is issued only when Entra ID detects an allowed address. Microsoft's documentation notes that where the address seen by the resource provider differs from the address seen by Entra ID, there is no enforcement until the resource redirects the session for re-evaluation. The strict location enforcement mode closes that window by blocking access as soon as the resource observes a disallowed address, but Microsoft is explicit that the mode requires dedicated and enumerable egress

addresses for both authentication traffic and resource traffic, and advises against enabling it where egress is shared or cannot be defined. That prerequisite is exactly what a global support organization, a split-tunnel VPN estate, or a broadly distributed workforce cannot reliably supply.

3.6. What Geographic Restrictions Still Provide

None of the preceding makes geographic restriction worthless. It makes it a filter rather than a boundary, and filters have legitimate and defensible uses. Four are worth stating explicitly.

- The first is volume reduction. Indiscriminate password spray and credential stuffing account for a large share of the authentication traffic directed at most tenants, and a substantial portion of that traffic originates from infrastructure that makes no attempt at evasion. Excluding countries in which an organization has no users, customers, or suppliers removes that traffic before it reaches downstream detection, which lowers analyst workload and improves the signal-to-noise ratio of the alerts that remain.
- The second is cost imposition. Forcing an adversary onto proxy or cloud infrastructure adds steps to their operation. Those steps cost money, introduce configuration that can be applied incorrectly, and generate additional artifacts that may be observable elsewhere. The effect is modest, but it is genuine and inexpensive to obtain.
- The third, and in practice the most valuable, is investigative context. Country of origin is a strong enrichment signal even where it is a weak enforcement signal. It underpins impossible travel and atypical location risk detections in Microsoft Entra ID Protection and Microsoft Defender for Cloud Apps, and it gives responders a fast means of triaging a suspicious sign-in. Microsoft's own guidance for identifying fraudulent remote workers rests substantially on this class of signal, recommending that organizations monitor for impossible travel, such as a supposedly domestic employee signing in from another country, and for the use of known public VPN services.
- The fourth is regulatory and contractual. Data residency commitments, sanctions and export control obligations, and customer contract terms may require a demonstrable restriction on the jurisdictions from which data can be accessed. In that context the control is evidence of intent and is auditable, and its resistance to a determined adversary is not the measure of its value.

3.7. Reconciling Geographic Restrictions with a Layered Model

Guidance recommending geographic policies as one element of a multilayered approach remains sound, provided the layer is weighted correctly. Defense in depth assumes that each layer contributes independent assurance and that no single layer is load bearing. Geographic restriction satisfies the first assumption and fails the second if it is relied upon in isolation. It belongs in the same tier as address reputation and network heuristics: useful for reducing volume and enriching telemetry, unsuitable as the mechanism that decides whether a determined adversary reaches a resource.

The load-bearing layers in a modern Entra ID deployment are identity and device assurance: phishing-resistant multifactor authentication, device compliance or Microsoft Entra hybrid join, token protection, and risk-based policy driven by Microsoft Entra ID Protection. Those controls act on attributes an adversary cannot alter by selecting a different exit node. Microsoft makes the same point in its own documentation, observing that where a cloud proxy is in place a policy requiring a compliant or hybrid joined device is easier to manage than one based on address, because keeping an up-to-date list of the addresses used by a cloud-hosted proxy or VPN solution is nearly impossible.

3.8. Operational Costs and Failure Modes

Geographic conditions are not free, and their costs fall entirely on the organization that deploys them. Five failure modes recur in practice.

- Mapping accuracy is the first. Entra ID resolves addresses to countries using a mapping table that is updated periodically and cannot be perfectly current. Carrier-grade network address translation, satellite and mobile roaming, IPv6 transition mechanisms, and recently reallocated address blocks all produce incorrect or unresolvable results. Addresses that cannot be mapped fall into the unknown category, which forces an explicit and uncomfortable choice between blocking legitimate but unmappable traffic and accepting a documented gap.
- Observed address substitution is the second. Where a cloud proxy, secure web gateway, or secure service edge platform sits in the path, Entra ID evaluates the address of that platform rather than the user's. Microsoft recommends Global Secure Access with source IP restoration to preserve the original address, but that is an additional platform dependency rather than a configuration change, and it does not apply uniformly to applications outside Microsoft 365.
- Availability and exception management is the third, and is the cost most often felt by the business. Business travel, incident response conducted from an unexpected location, **third-party support engagements**, and emergency access all collide with country conditions. Section 3.1 describes this from the service provider perspective: a global partner cannot supply a stable address list, so an address-based exception is not maintainable and an identity-based exclusion is the workable alternative.
- Scale and configuration drift is the fourth. Named locations are bounded, with documented limits of 195 named locations per tenant, 2,000 address ranges per named location, and CIDR masks greater than /8. Definitions decay as offices, carriers, and cloud providers change, and stale entries fail quietly in both directions, either admitting traffic that should be blocked or blocking traffic that should be admitted.
- False assurance is the fifth and the most consequential. A geographic condition produces visible, auditable block events, which makes it feel effective out of proportion to what it actually prevents. If that impression leads an organization to defer phishing-resistant authentication, device compliance, or token protection, the control has produced a net reduction in security posture.

3.9. Recommendations

The considerations below are intended to inform architecture and risk discussions. This document does not prescribe Conditional Access policy configuration. Any change to an access policy should be validated in report-only mode against the organization's own sign-in telemetry, with a tested emergency access path in place, before it is enforced.

Consideration	Rationale
Treat location as a signal, not a control	Country of origin is an inference drawn from the network path. Use it to reduce volume and enrich detection, and do not let it carry assurance that properly belongs to identity and device controls.
Anchor assurance in identity and device	Phishing-resistant multifactor authentication, device compliance or Microsoft Entra hybrid join, and token protection act on attributes an adversary cannot change by selecting a different exit node.
Prefer identity-based exceptions to address allow-lists	Address lists for global partners and service providers cannot be kept current. Scoping exclusions to named accounts or groups is maintainable and auditable, as described in Section 3.1.
Route country data into detection	Direct country, atypical location, and impossible travel signals to Microsoft Entra ID Protection, Microsoft Defender for Cloud Apps, and the security operations team rather than relying on block decisions alone.

Consideration	Rationale
Understand the limits of strict enforcement	Continuous access evaluation strict location enforcement closes the token replay window, but Microsoft requires dedicated and enumerable egress addresses for it. It should not be enabled where egress is shared or cannot be defined.
Decide the unknown-region case deliberately	Including or excluding unknown countries and regions should be an explicit, documented decision rather than a default, with the residual risk recorded either way.
Protect emergency and support access	Maintain emergency access accounts and a tested exclusion path so that a location condition cannot obstruct legitimate recovery, incident response, or authorized partner support.
Review on a defined cycle	Named locations decay. Re-validate definitions, exclusions, and business justification on a schedule, and retire entries that no longer reflect where the organization operates.

3.10. Summary Position

Geographic restriction in Entra ID Conditional Access is a legitimate capability that is frequently asked to do a job it cannot do. It reduces indiscriminate authentication noise, supplies valuable investigative context, and supports data residency and sanctions obligations. It does not stop a targeted adversary, because the country an authentication appears to originate from is an attribute of the network path and can be changed at will through a commercial VPN service, a residential proxy network, a compromised edge device, or a cloud instance provisioned in whichever region the policy requires.

The practical conclusion is one of weighting rather than exclusion. Geographic policies belong in a layered design as a low-assurance filter and a detection input, positioned alongside address reputation and network heuristics. The controls that actually determine whether a determined adversary reaches a resource are phishing-resistant authentication, device compliance, token protection, and risk-based policy driven by identity telemetry. Where a location condition would obstruct authorized global support, an identity-based exclusion preserves both the filter and the business outcome, which is the position set out in Section 3.1.

4. Associated Documents

4.1. Microsoft Reference Documents

- [Conditional Access: Network assignment. Microsoft Learn.](#)
- [Conditional Access: Block access by location. Microsoft Learn.](#)
- [Continuous access evaluation strict location enforcement in Microsoft Entra ID. Microsoft Learn.](#)
- [Enable source IP restoration with Global Secure Access. Microsoft Learn.](#)
- [How token protection enhances Conditional Access policies. Microsoft Learn.](#)
- [Overview of Conditional Access authentication strengths. Microsoft Learn.](#)
- [Password spray investigation playbook. Microsoft Learn.](#)
- [Alert classification for suspicious IP address related to password spray activity. Microsoft Learn.](#)

4.2. Microsoft Techniques Documents

- [Midnight Blizzard: Guidance for responders on nation-state attack. Microsoft Security Blog.](#)
- [Jasper Sleet: North Korean remote IT workers' evolving tactics to infiltrate organizations. Microsoft Security Blog.](#)
- [Detection strategies across cloud and identities against infiltrating IT workers. Microsoft Security Blog.](#)
- [Volt Typhoon targets US critical infrastructure with living-off-the-land techniques. Microsoft Security Insider.](#)

4.3. Government Documents

- [NIST SP 800-207 Zero Trust Architecture](#)
“Zero trust assumes there is no implicit trust granted to assets or user accounts based solely on their physical or network location...”
- [CISA – Zero Trust Maturity Model](#)
“Zero trust presents a shift from a location-centric model to a more data-centric approach for fine-grained security controls ...”
- [CISA - PRC State-Sponsored Cyber Actor Living off the Land to Evade Detection](#)
- [NCSC - Defending against China-nexus covert networks of compromised devices](#)
- [FBI - North Korean IT Worker Threats to U.S. Businesses](#)

4.4. Associated TD SYNnex Documents

- [Tech Note – Conditional Access for CSP Logins](#)
- [Tech Note – Exclude TD SYNnex from Conditional Access](#)
- [Tech Note – TD SYNnex Phish-resistant MFA](#)
- [Tech Note – TD SYNnex Tenant Access](#)
- [Tech Note – We Can't Open a Support Ticket](#)

5. Document Approval

This document has been approved by:

- Manager, Cloud Sales Engineering

6. Document Revision History

Number	Effective Date	Revision History	Author
1.0	9/5/2026	Initial Draft	David Bloom
1.1	9/8/2026	Minor updates	David Bloom

7. Appendix A – Glossary

Term	Definition
Conditional Access	The Microsoft Entra ID policy engine that evaluates signals such as user, group, application, device state, sign-in risk, and network location, and then grants, blocks, or conditions access. Policies are enforced after first-factor authentication completes.
Named Location	A Conditional Access object that groups public IPv4 ranges, IPv6 ranges, or countries and regions so that they can be included in or excluded from a policy. A named location may optionally be marked as trusted.
Geo-Restriction	An access restriction based on the country or region derived from the public IP address, or from the GPS coordinates, observed during authentication. Also referred to as geo-location blocking or geo-fencing.
Virtual Private Network (VPN)	A service that encapsulates a user's traffic and forwards it through an intermediate server, so that the traffic reaches the internet from that server's address and apparent country rather than from the user's own connection.
Adversary-in-the-Middle (AiTM)	A phishing technique in which a proxy relays traffic between the user and the legitimate sign-in service, capturing both the credential and the session artifacts issued after successful authentication.
Autonomous System Number (ASN)	An identifier assigned to a network operator that controls a block of internet addresses. Commonly used to judge whether an address belongs to a consumer, business, or hosting provider.
Continuous Access Evaluation (CAE)	A mechanism that allows a resource provider and Entra ID to respond to changes in user or session state during the lifetime of a token, rather than only at sign-in.
Global Secure Access	Microsoft's network access service. Its source IP restoration capability preserves the user's original public address for policy evaluation when traffic is routed through the service.
Hyperscaler	A large-scale public cloud provider offering on-demand compute, storage, and networking across multiple geographic regions.
Impossible Travel	A risk detection raised when two sign-ins for the same account occur from locations separated by a distance that could not be covered in the elapsed time.
Laptop Farm	A facility, typically operated by a local accomplice, that hosts employer-issued devices so they connect from the country the employer expects while the operator works from elsewhere.
Phishing-Resistant Multifactor Authentication	Authentication methods that are cryptographically bound to the legitimate service and cannot be relayed by a proxy, such as FIDO2 security keys, Windows Hello for Business, and certificate-based authentication.
Relay Network	Infrastructure assembled from compromised or rented hosts and network devices that forwards adversary traffic so it emerges from an address unrelated to the operator.
Remote Monitoring and Management (RMM)	Software used to administer devices remotely. Legitimate in normal operations and frequently abused to operate a device located in another country.
Residential Proxy	A service that forwards traffic through addresses assigned to consumer broadband or mobile subscribers, so that the traffic appears to originate from an ordinary household connection.

Geo-Restrictions in Conditional Access



Type:	7. Reference	Version:	1.1
Status:	Final	Effective:	9/8/2026

Term	Definition
Token Replay	Reuse of a stolen refresh token or session cookie to obtain access without re-authenticating, and therefore without a new evaluation of the location condition.

8. Appendix B – Summary of Techniques Used to Defeat Geographic Restrictions

The table below consolidates the techniques described in Section 3.5. It is provided as a reference for architecture and risk discussions and does not constitute configuration guidance.

Technique	How it presents to Entra ID	Publicly reported example
Commercial VPN or virtual private server	A clean public address that geolocates to whichever country the operator selects.	Jasper Sleet remote IT workers using VPN services, virtual private servers, and proxy services to conceal their location and identity.
Residential or mobile proxy network	A consumer broadband or mobile address inside the permitted country, indistinguishable from legitimate user traffic.	Midnight Blizzard routing password spray traffic through residential proxy networks to obfuscate the source of the attack.
Compromised edge devices and relay networks	A genuine in-country residential or small business address with clean reputation, often near the victim.	Volt Typhoon routing traffic through compromised small office and home office routers, firewalls, and VPN hardware.
Hyperscaler and cloud provider infrastructure	An address in the required cloud region, frequently reassigned and often shared across unrelated customers.	Compute provisioned on demand in a chosen region. Blocking provider ranges also blocks legitimate integrations and management traffic.
In-region foothold or legitimate remote access	An authentic in-country address belonging to a compromised host or a company-issued device.	Jasper Sleet laptop farms giving employer hardware an internet connection at the expected location while the operator connects from abroad.
Token theft and session replay	No location evaluation occurs. The stolen token was issued after the condition had already been satisfied.	Adversary-in-the-middle phishing and information-stealing malware. Partially addressed by continuous access evaluation strict location enforcement.

9. Appendix C – Positioning Geographic Restriction Within a Layered Model

The comparison below places geographic restriction alongside the other controls commonly deployed in an Entra ID environment. Assurance refers to how much confidence a control can carry on its own against a targeted adversary. It is not a measure of how useful the control is overall.

Control layer	Standalone assurance	Primary function in a layered design
Geographic and named location conditions	Low	Reduces indiscriminate authentication volume and enriches sign-in telemetry with country context.
Address reputation and network heuristics	Low	Filters known-bad infrastructure. Degrades quickly as adversaries rotate through new address space.
Phishing-resistant multifactor authentication	High	Prevents credential relay and adversary-in-the-middle interception at the point of authentication.
Device compliance or Microsoft Entra hybrid join	High	Binds access to a managed device in a known state that an adversary cannot substitute by changing network path.
Token protection and continuous access evaluation	High	Limits the value of stolen session artifacts and shortens the window in which a stale session remains usable.
Risk-based policy and identity telemetry	Medium to high	Detects anomalous behavior such as atypical location and impossible travel, and triggers step-up authentication.